30 Academic Papers for MCP Server Risk Scoring Research

This annotated bibliography identifies **30 papers across seven research categories** directly relevant to building a defense-oriented risk scoring framework where an MCP server evaluates and gates incoming agent requests. The papers span MCP-specific security, agent safety benchmarks, vulnerability scoring methodologies, API threat detection, dynamic risk assessment, zero trust for AI agents, and prompt injection defense. All papers are from 2020–2026, with the majority from 2024–2026.

---

1. MCP security: threats, defenses, and benchmarks

This category covers papers that directly analyze the Model Context Protocol's attack surface, propose defense architectures, or benchmark MCP-specific vulnerabilities. These are foundational for understanding what threats the risk scorer must detect.

Paper 1 — MCP Safety Audit: LLMs with the Model Context Protocol Allow Major Security Exploits

- **Authors:** Brandon Radosevich, John Halloran
- **Year:** April 2025
- **Venue:** arXiv preprint (arXiv:2504.03767)
- **URL:** https://arxiv.org/abs/2504.03767
- **Summary:** One of the earliest MCP security papers, demonstrating that leading LLMs (Claude, Llama-3.3-70B) can be coerced via MCP tools to compromise developer systems through malicious code execution, remote access, and credential theft. Introduces MCPSafetyScanner, the first automated agentic tool to audit the security of arbitrary MCP servers. Directly relevant as it identifies concrete vulnerability classes and provides an automated scanning methodology that could feed into static risk assessment.

Paper 2 — Model Context Protocol (MCP): Landscape, Security Threats, and Future Research Directions

- **Authors:** Xinyi Hou, Yanjie Zhao, Shenao Wang, Haoyu Wang
- **Year:** March 2025
- **Venue:** arXiv preprint (arXiv:2503.23278)
- **URL:** https://arxiv.org/abs/2503.23278
- **Summary:** Presents a systematic study defining the full MCP server lifecycle (creation, deployment, operation, maintenance) across 16 key activities, and constructs a comprehensive threat taxonomy across four major attacker types encompassing 16 distinct threat scenarios. Proposes fine-grained, actionable security safeguards tailored to each lifecycle phase. Provides the foundational threat taxonomy and lifecycle-based risk framework essential for categorizing risks in a scoring system.

Paper 3 — MCIP: Protecting MCP Safety via Model Contextual Integrity Protocol

- **Authors:** Huihao Jing, Haoran Li, Wenbin Hu, et al.
- **Year:** May 2025 (published at EMNLP 2025)
- **Venue:** EMNLP 2025; arXiv preprint (arXiv:2505.14590)

- **URL:** https://arxiv.org/abs/2505.14590
- **Summary:** Proposes the Model Contextual Integrity Protocol (MCIP), guided by the MAESTRO framework, to address MCP's missing safety mechanisms. Develops a fine-grained taxonomy of unsafe behaviors in MCP scenarios and creates benchmark and training data for evaluating LLMs' ability to identify MCP safety risks. Relevant through its contextual integrity framework that tracks information flows (sender, receiver, data subject, transmission principle) for runtime risk detection.

Paper 4 — Model Context Protocol (MCP) at First Glance: Studying the Security and Maintainability of MCP Servers

- **Authors:** Mohammed Mehedi Hasan, Hao Li, Emad Fallahzadeh, et al.
- **Year:** June 2025
- **Venue:** arXiv preprint (arXiv:2506.13538)
- **URL:** https://arxiv.org/abs/2506.13538
- **Summary:** The first large-scale empirical study evaluating 1,899 open-source MCP servers for health, security, and maintainability. Identifies 8 distinct vulnerability types (only 3 overlapping with traditional software vulnerabilities), finding **7.2% of servers contain general vulnerabilities** and **5.5% exhibit MCP-specific tool poisoning**. Provides empirical vulnerability prevalence data critical for calibrating risk score baselines.

Paper 5 — MCP-Guard: A Multi-Stage Defense-in-Depth Framework for Securing Model Context Protocol in Agentic AI

- **Authors:** Wenpeng Xing, Zhonghao Qi, Yupeng Qin, et al.
- **Year:** August 2025
- **Venue:** arXiv preprint (arXiv:2508.10991)
- **URL:** https://arxiv.org/abs/2508.10991
- **Summary:** Proposes MCP-Guard, a proxy-based three-stage defense: (1) lightweight static pattern scanning for overt threats, (2) a fine-tuned E5-based neural detector achieving **96.01% accuracy** on adversarial prompts, and (3) an LLM arbitrator for final decisions. Introduces MCP-AttackBench with **70,000+ samples** spanning 11 attack categories. The most architecturally aligned paper — its layered static → neural → LLM pipeline directly maps to a defense-oriented risk scoring pipeline.

Paper 6 — MCPSecBench: A Systematic Security Benchmark and Playground for Testing Model Context Protocols

- **Authors:** Yixuan Yang, Cuifeng Gao, Daoyuan Wu, et al.
- **Year:** August 2025
- **Venue:** arXiv preprint (arXiv:2508.13220)
- **URL:** https://arxiv.org/abs/2508.13220
- **Summary:** Formalizes secure MCP specifications and identifies **17 attack types across 4 primary attack surfaces** (tool, server, protocol, host). Tests across Claude, OpenAI, and Cursor reveal existing protections achieve less than 30% average success rate. Provides the most comprehensive attack surface enumeration and standardized evaluation methodology for MCP security.

Paper 7 — MCP-DPT: A Defense-Placement Taxonomy and Coverage Analysis for Model Context Protocol Security

- **Authors:** Mehrdad Rostamzadeh, Sidhant Narula, Nahom Birhan, et al.
- **Year:** April 2026

- **Venue:** arXiv preprint (arXiv:2604.07551)
- **URL:** https://arxiv.org/abs/2604.07551
- **Summary:** Introduces a defense-placement-oriented taxonomy organizing attacks by the architectural component responsible for enforcement rather than by attack technique. Maps threats across six MCP layers and reveals uneven, predominantly tool-centric protection with persistent gaps at host orchestration, transport, and supply-chain layers. Provides principled guidance on where mitigation responsibility should reside in a risk scoring architecture.

---

2. Agent safety benchmarks and risk assessment

These papers evaluate or defend against unsafe LLM agent actions, especially involving tool use. They define the threat behaviors, risk taxonomies, and evaluation methodologies that a server-side risk scorer must recognize.

Paper 8 — R-Judge: Benchmarking Safety Risk Awareness for LLM Agents

- **Authors:** Tongxin Yuan, Zhiwei He, Lingzhong Dong, et al.
- **Year:** January 2024 (EMNLP 2024 Findings)
- **Venue:** Findings of EMNLP 2024; arXiv (arXiv:2401.10019)
- **URL:** https://arxiv.org/abs/2401.10019
- **Summary:** Benchmark of 569 multi-turn agent interaction records across 27 risk scenarios and 10 risk types. Evaluates LLMs' ability to judge whether agent actions are safe. GPT-4o achieves only **74.42% accuracy**, exposing major gaps in risk awareness. Provides a taxonomy of risk types and a methodology for evaluating whether an LLM can serve as a safety judge — directly applicable to using LLMs as risk scorers in MCP server defense.

Paper 9 — GuardAgent: Safeguard LLM Agents by a Guard Agent via Knowledge-Enabled Reasoning

- **Authors:** Zhen Xiang, Linzhi Zheng, Yanjie Li, et al.
- **Year:** June 2024
- **Venue:** arXiv preprint (arXiv:2406.09187)
- **URL:** https://arxiv.org/abs/2406.09187
- **Summary:** Proposes GuardAgent, the first LLM agent designed as a guardrail for other LLM agents. Dynamically checks whether target agent inputs/outputs satisfy safety guard requests by generating task plans and translating them into executable guardrail code. Introduces benchmarks for healthcare access control and web agent safety. Demonstrates an architectural pattern for implementing a guard layer that inspects agent tool-call requests — analogous to MCP server risk-scoring middleware.

Paper 10 — AgentHarm: A Benchmark for Measuring Harmfulness of LLM Agents

- **Authors:** Maksym Andriushchenko, Alexandra Souly, Mateusz Dziemian, et al.
- **Year:** October 2024 (ICLR 2025)
- **Venue:** ICLR 2025; arXiv (arXiv:2410.09024)
- **URL:** https://arxiv.org/abs/2410.09024
- **Summary:** Provides 110 explicitly malicious agent tasks (440 with augmentations) across 11 harm categories including fraud, cybercrime, and harassment. Key finding: leading LLMs are **surprisingly compliant with malicious agent requests** even without jailbreaking. Defines harm categories and

scoring methodology directly applicable to classifying the risk of tool-call sequences arriving at an MCP server.

Paper 11 — Agent Security Bench (ASB): Formalizing and Benchmarking Attacks and Defenses in LLM-based Agents

- **Authors:** Hanrong Zhang, Jingyuan Huang, Kai Mei, et al.
- **Year:** October 2024 (ICLR 2025)
- **Venue:** ICLR 2025; arXiv (arXiv:2410.02644)
- **URL:** https://arxiv.org/abs/2410.02644
- **Summary:** Comprehensive security framework covering 10 scenarios, 10 agents, 400+ tools, and 27 attack/defense methods across ~**90,000 test cases**. Benchmarks prompt injection, memory poisoning, and a novel Plan-of-Thought backdoor attack. Finds highest average attack success rate of **84.30%** with limited defense effectiveness. Systematically tests the tool-use attack surface that an MCP server risk scorer must defend against.

Paper 12 — ToolEmu: Identifying the Risks of LM Agents with an LM-Emulated Sandbox

- **Authors:** Yangjun Ruan, Honghua Dong, Andrew Wang, et al.
- **Year:** September 2023 (ICLR 2024 Spotlight)
- **Venue:** ICLR 2024 Spotlight; arXiv (arXiv:2309.15817)
- **URL:** https://arxiv.org/abs/2309.15817
- **Summary:** Uses GPT-4 to emulate tool execution in a virtual sandbox, enabling scalable safety evaluation without implementing real tools. Includes an LM-based automatic safety evaluator quantifying risk severity across 9 failure categories. Even the safest agent fails with potentially severe outcomes **23.9%** of the time. Pioneered the approach of using LLM-based emulation and automated risk scoring for tool-use agents — a core technique applicable to MCP server risk assessment.

Paper 13 — InjecAgent: Benchmarking Indirect Prompt Injections in Tool-Integrated Large Language Model Agents

- **Authors:** Qiusi Zhan, Zhixiang Liang, Zifan Ying, Daniel Kang
- **Year:** March 2024 (ACL 2024 Findings)
- **Venue:** Findings of ACL 2024; arXiv (arXiv:2403.02691)
- **URL:** https://arxiv.org/abs/2403.02691
- **Summary:** First benchmark specifically for indirect prompt injection (IPI) attacks against tool-integrated LLM agents. Contains 1,054 test cases across 17 user tools and 62 attacker tools, categorizing attack intentions into direct harm and data exfiltration. ReAct-prompted GPT-4 is vulnerable **24% of the time**, rising to ~47% with enhanced attacks. IPI through tool-returned data is a primary threat vector for MCP servers where external content could hijack agent behavior.

Paper 14 — AgentDojo: A Dynamic Environment to Evaluate Prompt Injection Attacks and Defenses for LLM Agents

- **Authors:** Edoardo Debenedetti, Jie Zhang, Mislav Balunović, et al.
- **Year:** June 2024 (NeurIPS 2024 Datasets & Benchmarks)
- **Venue:** NeurIPS 2024; arXiv (arXiv:2406.13352)
- **URL:** https://arxiv.org/abs/2406.13352
- **Summary:** An extensible dynamic evaluation framework for testing LLM agent robustness against prompt

injection in tool-augmented workflows. Includes 97 realistic tasks, 629 security test cases, and 70 tools across banking, Slack, travel, and workspace domains. Existing defenses are found insufficient. Models the exact threat model of an MCP server: agents executing tools over untrusted data where returned data may contain prompt injections.

---

3. AI and agentic vulnerability scoring systems

These papers evaluate or propose numeric scoring methodologies for AI-specific vulnerabilities — directly informing how to design the risk score formula in the MCP framework.

Paper 15 — On the Validity of Traditional Vulnerability Scoring Systems for Adversarial Attacks against LLMs

- **Authors:** Atmane Ayoub Mansour Bahar, Ahmad Samer Wazan
- **Year:** December 2024
- **Venue:** arXiv preprint (arXiv:2412.20087); also IEEE Xplore
- **URL:** https://arxiv.org/abs/2412.20087
- **Summary:** Investigates whether CVSS, DREAD, and OWASP Risk Rating can effectively evaluate adversarial attacks against LLMs. Evaluates 56 adversarial attacks using three LLMs as automated assessors and finds that existing scoring systems produce **minimal variation across different attacks**, demonstrating that traditional metrics with rigid value sets are inadequate for LLM-specific threats. Provides critical motivation for designing new, flexible scoring metrics tailored to AI/LLM systems rather than adapting traditional CVSS.

Paper 16 — Graph of Effort: Quantifying Risk of AI Usage for Vulnerability Assessment

- **Authors:** Anket Mehra, Andreas Aßmuth, Malte Prieß
- **Year:** March 2025
- **Venue:** arXiv preprint (arXiv:2503.16392); Proc. 16th International Conference on Cloud Computing 2025
- **URL:** https://arxiv.org/abs/2503.16392
- **Summary:** Introduces the "Graph of Effort" (GOE), a novel quantitative threat modeling method that scores the effort required to use offensive AI for exploiting vulnerabilities. GOE assigns **numeric scores (0–5)** at each step of the intrusion kill chain and can be combined with CVSS for comprehensive analysis. Provides a concrete numeric scoring methodology that quantifies AI-specific threat dimensions — directly applicable to scoring the risk that AI agents pose when accessing MCP server tools.

Paper 17 — Securing Agentic AI: Threat Modeling and Risk Analysis for Network Monitoring Agentic AI System

- **Authors:** Pallavi Zambare, Venkata Nikhil Thanikella, Ying Liu
- **Year:** August 2025
- **Venue:** arXiv preprint (arXiv:2508.10043); submitted to IEEE Transactions on Privacy
- **URL:** https://arxiv.org/abs/2508.10043
- **Summary:** Applies the MAESTRO (Multi-Agent Environment, Security, Threat, Risk, & Outcome) seven-layer framework to an actual agentic AI prototype. Uses a qualitative threat scoring model where **R = P(likelihood) × I(impact)** for each identified threat. Proposes defense-in-depth with memory isolation, planner validation, and real-time anomaly response. Directly demonstrates risk scoring applied to agentic

AI systems with tool-use capabilities, validating MAESTRO for operational threat mapping applicable to MCP server risk evaluation.

Paper 18 — OWASP AI Vulnerability Scoring System (AIVSS) v0.5

- **Authors:** OWASP Foundation contributors (Agentic AI Core Risks team)
- **Year:** 2025 (ongoing)
- **Venue:** OWASP Foundation (published framework with open-source calculator)
- **URL:** https://aivss.owasp.org/
- **Summary:** Extends CVSS with AI-specific metrics including Model Robustness, Data Sensitivity, Exploitation Impact, Decision Criticality, Adversarial Difficulty, **Agent Autonomy**, Lateral Leverage, Goal Vulnerability, and Context Sensitivity. Each AI-specific metric is scored 0.0–1.0, combined with a ModelComplexityMultiplier. Covers agentic AI risks including tool squatting, memory poisoning, and agent identity impersonation. The emerging industry-standard scoring methodology for AI/agentic vulnerabilities, directly applicable to the MCP server risk scoring formula.

---

4. API risk scoring and gateway security

These papers address runtime threat detection and scoring of API requests — the architectural pattern closest to how an MCP server would evaluate incoming tool-call requests.

Paper 19 — Adoption of Deep-Learning Models for Managing Threat in API Calls with Transparency Obligation Practice for Overall Resilience

- **Authors:** Nihala Basheer, Shareeful Islam, Mohammed K S Alwaheidi, Spyridon Papastergiou
- **Year:** July 2024
- **Venue:** Sensors (MDPI), 24(15):4859
- **URL:** https://doi.org/10.3390/s24154859
- **Summary:** Proposes an integrated architecture combining ANN and MLP deep-learning models for threat detection from API call datasets, achieving **88–91% accuracy**. Maps extracted features → CWE weaknesses → CAPEC threats → NIST SP 800-53 controls. Also introduces transparency dimensions aligned with EU AI Act requirements. Demonstrates an end-to-end pipeline from API call feature extraction through threat scoring to control selection — directly applicable to scoring API-level threats in MCP server request processing.

Paper 20 — Intelligent Threat Detection and Prevention in REST APIs Using Machine Learning

- **Authors:** Muhammad Sohail
- **Year:** April 2025
- **Venue:** International Journal of Science and Research Archive (IJSRA), 15(02), pp. 012–027
- **URL:** https://doi.org/10.30574/ijsra.2025.15.2.1281
- **Summary:** Proposes an ML-based framework for detecting and preventing malicious activity in REST API traffic using isolation forests, LSTM-based anomaly detectors, and decision trees. Incorporates reinforcement learning for dynamic security policy adjustment (rate limits, IP bans) achieving **92–97% detection accuracy**. Demonstrates dynamic, adaptive API request scoring that adjusts in real-time — the architectural pattern needed for runtime MCP request risk scoring.

Paper 21 — Machine Learning-Based Detection of API Security Attacks

- **Authors:** Isha Sharma, Amanpreet Kaur, Keshav Kaushik, Gaurav Chhabra
- **Year:** 2024
- **Venue:** Springer LNNS, vol. 821 (ICDSA 2023)
- **URL:** https://doi.org/10.1007/978-981-99-7814-4_23
- **Summary:** Studies ML techniques for detecting API security attacks referencing OWASP API Security Top 10 categories. Evaluates multiple classifiers for detecting API abuse patterns including broken authentication, excessive data exposure, and injection attacks. Maps OWASP API risk categories to ML detection capabilities, providing a template for classifying and scoring MCP server request risks by attack type.

---

5. Dynamic risk assessment in cybersecurity

These papers provide the theoretical and methodological foundations for dynamic/runtime risk scoring — the core engine behind the MCP framework's runtime mode.

Paper 22 — Dynamic Risk Assessment in Cybersecurity: A Systematic Literature Review

- **Authors:** Pavlos Cheimonidis, Konstantinos Rantos
- **Year:** 2023
- **Venue:** Future Internet (MDPI), 15(10), Article 324
- **URL:** https://doi.org/10.3390/fi15100324
- **Summary:** Systematic literature review analyzing 50 dynamic risk assessment (DRA) models for cybersecurity, categorized by primary analysis methods (Bayesian networks, attack graphs, machine learning). Defines DRA as "the continuous process of identifying and assessing risks to organisational operations in near real-time" and identifies key gaps including limited real-world deployment. The taxonomy of DRA methods provides a structured basis for selecting techniques for runtime MCP server risk scoring.

Paper 23 — Exploit Prediction Scoring System (EPSS)

- **Authors:** Jay Jacobs, Sasha Romanosky, Benjamin Edwards, Michael Roytman, Idris Adjerid
- **Year:** 2021 (journal); preprint 2019
- **Venue:** Digital Threats: Research and Practice (ACM), 2(3), Article 20; arXiv:1908.04856
- **URL:** https://dl.acm.org/doi/10.1145/3436242
- **Summary:** Presents the first open, data-driven framework for estimating the probability that a CVE will be exploited in the wild within 12 months, using ML trained on real-world exploitation data with **1,100+ features**. EPSS scores are updated daily and complement CVSS — while CVSS measures severity, EPSS measures likelihood. Its approach to probabilistic, data-driven vulnerability prioritization directly informs how an MCP risk scorer could dynamically weight threat levels based on observed exploitation patterns.

Paper 24 — Time to Change the CVSS?

- **Authors:** Jonathan M. Spring, Eric Hatleback, Allen D. Householder, Art Manion, Deana Shick
- **Year:** 2021
- **Venue:** IEEE Security & Privacy, 19(2), pp. 74–78

- **URL:** https://doi.org/10.1109/MSEC.2020.3044475
- **Summary:** Argues that CVSS is inadequate both for capturing vulnerability severity and as a proxy for risk. The scoring algorithm is neither formally nor empirically justified, yet compliance bodies use it directly as risk scores. Advocates for decision-theoretic alternatives like SSVC (Stakeholder-Specific Vulnerability Categorization). Critical for understanding why a runtime risk scoring system should not rely solely on CVSS-style base scores but must incorporate context, exploit likelihood, and asset criticality — exactly the multi-factor scoring an MCP risk assessor requires.

---

6. Zero trust architecture for AI agents

These papers apply zero trust principles to AI agent systems — providing the trust model and continuous verification architecture that underpins server-side risk gating.

Paper 25 — Caging the Agents: A Zero Trust Security Architecture for Autonomous AI in Healthcare

- **Authors:** Saikat Maiti
- **Year:** March 2026
- **Venue:** arXiv preprint (arXiv:2603.17419)
- **URL:** https://arxiv.org/abs/2603.17419
- **Summary:** Presents a production-deployed security architecture for nine autonomous AI agents at a healthcare technology company. Develops a six-domain threat model covering credential exposure, execution capability abuse, network egress exfiltration, prompt integrity failures, database access risks, and file system access risks. Directly demonstrates a real-world zero trust architecture for AI agents, providing a concrete blueprint for defense-oriented MCP server risk scoring — particularly around least-privilege enforcement and continuous monitoring of agent actions.

Paper 26 — A Novel Zero-Trust Identity Framework for Agentic AI: Decentralized Authentication and Fine-Grained Access Control

- **Authors:** Ken Huang, Vineeth Sai Narajala, John Yeoh, et al.
- **Year:** May 2025
- **Venue:** arXiv preprint (arXiv:2505.19301)
- **URL:** https://arxiv.org/abs/2505.19301
- **Summary:** Proposes a comprehensive IAM framework for multi-agent systems using Decentralized Identifiers (DIDs), Verifiable Credentials (VCs), an Agent Naming Service for capability-aware discovery, and dynamic fine-grained access control. Explores Zero-Knowledge Proofs for privacy-preserving policy compliance. Addresses the identity and access management gap for AI agents — key to any MCP risk-scoring framework that needs to verify agent identities, enforce least-privilege tool access, and manage trust dynamically.

Paper 27 — Secure Multi-LLM Agentic AI and Agentification for Edge General Intelligence by Zero-Trust: A Survey

- **Authors:** Yinqiu Liu, Ruichen Zhang, Haoxiang Luo, et al.
- **Year:** 2025
- **Venue:** arXiv preprint (arXiv:2508.19870)
- **URL:** https://arxiv.org/abs/2508.19870

- **Summary:** A comprehensive survey covering zero-trust security for multi-LLM agentic AI systems at the edge. Examines how agents collaborate across heterogeneous edge infrastructures and applies the "never trust, always verify" principle to multi-LLM agentic settings. Provides a broad survey of trust models and verification mechanisms that inform risk scoring across distributed MCP server deployments.

---

7. Prompt injection and tool poisoning defense

These papers address the specific attack vectors (indirect prompt injection and tool poisoning) that represent the highest-risk threat categories for MCP servers processing agent requests.

Paper 28 — Prompt Injection Attack to Tool Selection in LLM Agents (ToolHijacker)

- **Authors:** Jiawen Shi, Zenghui Yuan, Guiyao Tie, et al.
- **Year:** April 2025
- **Venue:** arXiv preprint (arXiv:2504.19793)
- **URL:** https://arxiv.org/abs/2504.19793
- **Summary:** Introduces ToolHijacker, a prompt injection attack targeting tool selection by injecting malicious tool documents into the tool library. Formulates tool document crafting as an optimization problem with a two-phase strategy. Evaluates six defense categories (StruQ, SecAlign, known-answer detection, DataSentinel, perplexity detection) — all found insufficient. Demonstrates the tool poisoning threat vector and systematically evaluates defenses, highlighting gaps that a risk-scoring framework must account for in tool metadata integrity verification.

Paper 29 — System-Level Defense against Indirect Prompt Injection Attacks: An Information Flow Control Perspective

- **Authors:** Fangzhou Wu, Ethan Cecchetti, Chaowei Xiao
- **Year:** September 2024
- **Venue:** arXiv preprint (arXiv:2409.19091)
- **URL:** https://arxiv.org/abs/2409.19091
- **Summary:** Presents "f-secure LLM systems," a system-level defense based on information flow control principles. Disaggregates LLM components into a context-aware pipeline with dynamically generated structured executable plans, with a security monitor that filters untrusted input. Provides formal security guarantees while preserving functionality. Highly relevant as it offers a formal, principled approach to preventing indirect prompt injection — applicable as a foundational architecture for separating trusted and untrusted data flows in MCP tool interactions.

Paper 30 — FATH: Authentication-based Test-time Defense against Indirect Prompt Injection Attacks

- **Authors:** Jiongxiao Wang, Fangzhou Wu, Wendi Li, et al.
- **Year:** October 2024
- **Venue:** arXiv preprint (arXiv:2410.21492)
- **URL:** https://arxiv.org/abs/2410.21492
- **Summary:** Introduces FATH (Formatting Authentication with Hash-based Tags), a test-time defense using an authentication system with hash-based tags to label responses, enabling selective filtering of outputs to user instructions only. Achieves near **0% attack success rate** on GPT-3.5 and effectively defends against optimization-based attacks on Llama3. Tested on the InjecAgent tool-usage benchmark.

Provides a practical, zero-trust-aligned authentication mechanism for distinguishing legitimate from injected instructions at runtime — directly applicable as a verification layer in MCP server risk scoring.

How these papers map to the MCP risk scoring framework

The 30 papers above form a coherent research foundation for the defense-oriented MCP risk scoring project. The **static (design-time) scoring mode** draws primarily from papers on threat taxonomies (Papers 2, 6, 7), vulnerability scoring methodologies (Papers 15–18), and CVSS/EPSS analysis (Papers 23, 24). The **dynamic (runtime) scoring mode** draws from dynamic risk assessment frameworks (Paper 22), Bayesian and probabilistic approaches (Paper 23), API request-level threat detection (Papers 19–21), and multi-stage defense pipelines (Paper 5). The **agent-as-threat-source framing** is grounded in agent safety benchmarks (Papers 8–14), zero trust agent architectures (Papers 25–27), and prompt injection/tool poisoning defenses (Papers 28–30) that characterize exactly the attack patterns flowing client → server that the risk scorer must detect.

Category	Count	Date Range	Key Venues
MCP Security	7	2025–2026	arXiv, EMNLP 2025
Agent Safety Benchmarks	7	2023–2024	ICLR 2024/2025, NeurIPS 2024, ACL 2024, EMNLP 2024
AI Vulnerability Scoring	4	2024–2025	arXiv, IEEE, OWASP
API Risk Scoring	3	2024–2025	MDPI Sensors, Springer LNNS
Dynamic Risk Assessment	3	2021–2023	MDPI Future Internet, ACM, IEEE S&P
Zero Trust for AI	3	2025–2026	arXiv
Prompt Injection Defense	3	2024–2025	arXiv